TableOS — Roles, Permissions & Access

How accounts, organizations, workspaces, bases and roles work today, every rule in the code, the gaps, and a recommended model

Document version **4** — roles **R4**, TableOS **0.16.0** (version 1 described 0.13.0, commit `c2f239a`)
Prepared: 19 October 2026
Source: the TableOS code base (server permission checks, database schema, web screens) and tests run on a local copy of the system. Statements marked tested were reproduced on the local test system while writing this document.

Contents

1. Version history and gap status (start here)
2. Summary in plain words
3. The building blocks
4. How accounts, organizations and workspaces come into being today
5. The role layers (organization, workspace, base, field, device)
6. How TableOS decides what someone can do
7. Who can give access, and how
8. Full privilege matrix (every feature)
9. Security controls
10. Account types: what each person actually sees
11. Gaps and risks
12. Recommended model and decisions needed
13. Appendix A — API route → permission map
14. Appendix B — Where it lives in the code and database

0. Version history and gap status

This document is updated with every release that changes who can do what. Sections 1–11 describe the system as it was in **0.13.0** (roles R1), and the evidence for each gap. This section says what has changed since; where it disagrees with sections 1–11, this section is current. The running history is in `docs/roles-and-permissions/ROLES-CHANGELOG.md`.

Document	Roles	TableOS	What it describes
1	R1	0.13.0	Starting point: open sign-up, a personal organization for everyone, anyone could create workspaces, copy or export bases.
2	R2	0.14.0	Phase 1 of the questionnaire: sign-up by invitation or allowed email domain; no personal organizations; Owners and Admins create workspaces and bases, duplicate and export; contacts need a workspace role.
3	R3	0.15.0	Phase 2: three account types (Owner, Admin, Member); several Owners and Transfer ownership; Admins manage Members but open only what an Owner gives them; invitations with an account type; Workspace Owner role can be given; one invite form.
4	**R4**	**0.16.0**	**Phase 3**: two-factor required for everyone; sessions end after 30 days without activity; share links for Creators with "allow copy" enforced; Owners and Creators always edit fields; automation "Runs as"; hidden notifications for closed bases; move a base to another workspace; member emails for managers only; Activity log.
—	—	later	Interface-only role (G10), postponed (B12).

What changed in 0.14.0

Area	Before (R1)	Now (R2)
Creating an account	Anyone	Only with a pending invitation, or an email at a domain the organization allows (Members & access → Security). Domain sign-ups join as a Member with no access; Owners and Admins are notified. Everyone else: "TableOS accounts are by invitation only".
Own organization on sign-up	Everyone	Nobody (only the very first account on a brand-new installation).
Create a workspace	Everyone	Owners and Admins; they choose the organization when they run several.
Create a base	Workspace Creators and up	Owners and Admins
Duplicate a base	Anyone who could open it, into any workspace	Owners and Admins, into a workspace of the same organization
Export CSV / Excel	Anyone who could open the table	Owners and Admins (copy and paste in the grid still works)
Contacts directory	Every organization member	People with a role on that workspace
Deleted organizations	Still listed	Hidden from every list

What changed in 0.16.0

Area	Before (R3)	Now (R4)
Two-factor sign-in	Optional	**Required for everyone.** Without it, a signed-in person only sees "Set up two-factor sign-in"; it can't be turned off. Owners stay exempt from lockout and device approval. Automations and API tokens are unaffected.
Sessions	Never expired	End after **30 days without activity**; each visit restarts the 30 days.
Share links	Editors and up; "allow copy" only hid a button	**Creators and up.** With copy off: no copy, cut, drag or right-click on the shared page, attachments without download links, 50 records per request.
Field permission "Nobody"	Locked out the Owner and Creators too	Owners and Creators can always edit.
Automations	Ran as whoever saved them last	**"Runs as ..."** is shown and a Creator picks another Creator; saving doesn't change it.
Notifications	Stayed after losing access	Hidden for bases you can't open.
Moving bases	Not possible	**Move to workspace...** (same organization; Owners, Admins, or Workspace Owner of both). Everything moves; roles from the old workspace stop applying.
Member emails	Visible to every member	Owners, Admins and Workspace Owners only; others see names.
Audit log	Device log only	**Activity** tab for Owners and Admins, with filters.

What changed in 0.15.0

Area	Before (R2)	Now (R3)
Account types	Owner, Admin, Billing admin, Member, Guest (only Owner and Member in use)	**Owner, Admin, Member.** Billing admin and Guest removed.
Owners	Exactly one, no transfer	One or more. Only Owners change account types. **Transfer ownership**: the other person becomes Owner, you become Admin. At least one Owner always remains.
Admins: data	Automatic Owner of every workspace	Only the workspaces and bases an Owner gives them.
Admins: people	Nothing	Invite Members; change their roles, end dates and No access; suspend or remove them; approve or revoke their devices. Only where the Admin is Creator, and never above the Admin's own role. Never Owners, other Admins or themselves.
Admins: organization	Create workspaces and bases	Create workspaces; rename or delete any workspace; create API tokens (their own only); change security settings; see the device log. No billing.
Invitations	Owner only; always to a workspace or base; always Member	Owners and Admins. Owners can invite Admins and Owners, with or without a workspace. Accepting never lowers an account type.
Workspace Owner role	Couldn't be given	Owners and Admins can give it.
Invite screens	Home Share always gave the whole workspace	One form everywhere: whole workspace or selected bases.

Gap status

Gap	Status	Note
G1 personal organizations	closed 0.14.0	No new ones. The 13 existing ones on live were removed on 19 Oct 2026 (reversible).
G2 duplicate copies data out	closed 0.14.0	Live check: no base had been copied into another organization.
G3 everyone creates workspaces	closed 0.14.0	
G4 export can't be restricted	closed 0.14.0	Owners and Admins only.
G5 open sign-up	closed 0.14.0	Invitation or allowed domain (@bluecascade.org and @gmail.com on live).
G6 single Owner	closed 0.15.0	Several Owners, transfer.
G7 half-built Admin, unused roles	closed 0.15.0	Owner, Admin, Member only; Admin as in B3.
G8 delegated invites	closed 0.15.0	Admins invite; Workspace Owner role can be given.
G9 contacts open to all	closed 0.14.0	
G10 interface-only	postponed	Keep roles minimal for now (B12).
G11 two invite screens	closed 0.15.0	One form everywhere.
G12 sessions never expire	closed 0.16.0	30 days without activity.
G13 two-factor optional	closed 0.16.0	Required for everyone; Owners keep the lockout/device exemption (B11).
G14 share links	closed 0.16.0	Creators and up; "allow copy" enforced.
G15 "Nobody" locks out Owners	closed 0.16.0	Owners and Creators always edit.
G16 Runs as	closed 0.16.0	Shown; Creators choose.
G17 old notifications	closed 0.16.0	Hidden after losing access.
G18 move base	closed 0.16.0	Move to workspace…
G19 member emails	closed 0.16.0	Managers only.
G20 audit screen	closed 0.16.0	Activity tab.

1. Summary in plain words

TableOS copies Airtable's three-level model: **Organization** → **Workspace** → **Base**. A role given on a workspace applies to every base in it; a role given on a base applies to that base only. Inside a base there are four roles: **Creator, Editor, Commenter, Viewer**. On top of roles there are **field permissions** (who may edit a field's values) and **device approval** (a member's new browser must be approved by the owner).

The part that causes most confusion: **every person who signs up automatically gets their own organization**, in which they are the Owner, with a workspace called "Home". That is also true for people you invite. So an invited member is, at the same time, a limited member of *your* organization and the Owner of *their own* organization. Their Home page mixes both, and in their own organization they can create workspaces and bases freely.

Most important problems found

1. **Anyone with access to one of your bases — even a Viewer — can copy the entire base, with all its records, into their own workspace** and becomes Creator of the copy. tested
2. **Everybody can create workspaces**, because everybody is the Owner of the personal organization created at sign-up. tested
3. **Every role, including Viewer, can download every table as CSV/Excel**; there is no setting to restrict export. tested
4. **Only one person (the organization Owner) can manage people**; the Admin role exists in the database but cannot be assigned, and ownership cannot be transferred.
5. **Sign-up is open to anyone** who reaches the site, and every sign-up creates a new organization.

Section 10 lists all 20 gaps with evidence. Section 11 proposes an Airtable-aligned model with clear settings (for example "Who can create workspaces: Owners and Admins only") and a three-phase plan, plus the decisions we need from you.

2. The building blocks

Thing	What it is	Created by
Account (user)	A person: email + password (+ optional two-factor). One account can belong to several organizations.	Anyone, via *Create an account*.
Organization	The company / tenant. Owns workspaces, members, devices, API tokens, security settings and the plan. Every member has an *organization role*.	Created automatically at every sign-up, named "<Name>'s workspace".
Workspace	A folder of bases inside an organization. Its purpose is to give one role that covers many bases (including bases added later).	"Home" is created at sign-up; more via + *Create workspace* (Owner of the organization).
Base	A database: tables, fields, records, views, automations, interfaces, forms. The unit most roles are about.	Workspace Owner or Creator.
Table, field, record, view	Inside a base. Views can be *collaborative* (everyone), *personal* (only you) or *locked* (only the view's author or a base Creator can change it).	See matrix (section 7).
Interface	An app-like page built on a base.	Base Creator.

Share link	A public (optionally password-protected, optionally expiring) link to a view, a whole base (read-only) or a form (submit-only).	Base Editor or Creator.
Automation	Trigger + actions; runs with the access of the person who last saved it.	Base Creator.
API token	Key for programs (`tos_…`) with read/write/delete scopes, all bases or chosen ones.	Organization Owner only.
Device	A browser, identified by a long-lived cookie. In organizations that require approval, a member's new device waits for the Owner.	Registered automatically at first sign-in.

3. How accounts, organizations and workspaces come into being today

3.1 Sign-up

Signing up (`POST /v1/auth/signup`, public) does all of this in one step (`apps/server/src/modules/auth/routes.ts` lines 173–221):

1. creates the account;
2. creates a new organization named "<Name>'s workspace" of kind `personal`;
3. makes the person its **Owner**;
4. creates a workspace **Home** and gives the person the **workspace Owner** role on it;
5. starts a free plan for that organization.

3.2 Being invited

When the Owner of organization A invites someone, the invitation is for a workspace (all its bases) or for selected bases. Accepting it (`POST /v1/invitations/accept`) adds the person to organization A with the organization role **member** and creates the workspace or base role. The invited person must sign in (or sign up) with the invited email address — and if they sign up, they also get their own personal organization from step 3.1.

```
Arslan signs up
└── Organization "Arslan's workspace"     Arslan = Owner
    └── Workspace "Home"                    Arslan = workspace Owner
        └── Base "Signize.us"

Arslan invites Mahad to the base "Signize.us" as Editor.
Mahad signs up and accepts:
├── Organization "Mahad's workspace"     Mahad = Owner      (created by his sign-up)
│   └── Workspace "Home"                   Mahad = workspace Owner
│       └── (anything Mahad creates here is outside Arslan's control)
└── Organization "Arslan's workspace"    Mahad = member
    └── Workspace "Home"                   (visible to Mahad, showing only Signize.us)
        └── Base "Signize.us"              Mahad = Editor
```

On Mahad's Home page both organizations' workspaces appear together, both called "Home". The + *Create workspace* button creates the workspace in **his own** organization (the first one he owns, `workspace/routes.ts` lines 80–99). tested — an invited Viewer had two organizations (own: Owner, company: member), two "Home" workspaces, and created a new workspace (HTTP 201).

3.3 Creating workspaces and bases

- **Workspace:** the server allows it to anyone who is Owner of an organization, and puts it in the first organization they own. Because every account owns its personal organization, in practice **everyone can create workspaces**. The creator becomes workspace Owner.
- **Base:** needs *Owner* or *Creator* on the workspace (or organization Owner/Admin). The creator becomes base Creator.

4. The role layers

4.1 Organization roles

Role	How someone gets it	What it gives	Status
Owner	Signing up (own organization). Cannot be given or transferred.	Acts as Owner of every workspace (full access to every base). **Only role** that can invite, change roles, set access dates, suspend/remove members, approve/revoke devices, create API tokens, change security settings, create workspaces. Never needs device approval; never locked out by wrong passwords.	In use
Admin	Nowhere — no screen or API assigns it.	Same data access as Owner (Owner of every workspace), but **cannot** invite or manage access.	Half-built, unreachable
Billing admin	Nowhere.	Only: upgrade the plan / checkout.	Unused
Member	Accepting an invitation.	Nothing by itself. Only the workspace/base roles below give access.	In use
Guest	Nowhere.	Defined in the database only.	Unused

A membership can be **active**, **suspended** (keeps roles, can open nothing) or **deactivated** (removed: every role and device in that organization deleted).

4.2 Workspace roles

Role	How someone gets it	Effect
Owner	Automatically, by creating the workspace (or signing up for "Home"). Cannot be assigned to others.	Rename/delete the workspace; create bases; Creator on every base; cannot be restricted on any base.
Creator	Invitation to the workspace, or Members & access.	Create bases in the workspace; Creator on every base.
Editor	Same.	Editor on every base.
Commenter	Same.	Commenter on every base.
Viewer	Same.	Viewer on every base.

4.3 Base roles

Creator, Editor, Commenter, Viewer (see the matrix in section 7) plus:

- **No access to this base** (stored as role `none`, since 0.11.0): blocks one base that a workspace role would otherwise open.
- **Interface only**: defined (read records and views through an interface) but not offered anywhere yet.

4.4 Field permissions (per field)

Field header → *Edit field permissions* (needs Creator). Levels: **Editors and up** (default) · **Creators and up** · **Specific people** · **Nobody**. They only limit *editing values*; everyone who can open the base still sees the field. "Nobody" also blocks the Owner and Creators (`schema/field-permissions.ts` line 35). Automations and restores are not limited by field permissions.

4.5 Time limits and status

- **Access until**: any workspace or base role can end automatically on a date.
- **Suspend** / **Reactivate**: blocks everything immediately, keeps the roles.
- **Remove**: deletes all roles and devices in the organization (the person's own personal organization is untouched).

5. How TableOS decides what someone can do

For every request on a base, the server computes one **effective base role** (`packages/permissions/src/snapshot.ts`, `apps/server/src/modules/access/compile.ts`):

1. The browser's device must not be blocked in that organization (device approval) — otherwise the organization is invisible.
2. The person must be an **active** member of the organization — otherwise no access at all.
3. Organization **Owner or Admin** → treated as workspace Owner → **Creator**.
4. Workspace **Owner** → **Creator**, whatever the base says.
5. Otherwise, if the base has its own setting, **it wins** (higher, lower, or *No access*).
6. Otherwise the base inherits the workspace role.
7. Expired roles count as no role. No role = no access (the base is not listed and returns "not found").

The effective role is then checked against the action the request needs (for example `record.update`), and field permissions / synced-field rules are applied on writes.

Example	Workspace role	Base setting	Result on that base
Normal workspace member	Editor	—	Editor
Promoted on one base	Viewer	Creator	Creator
Restricted on one base	Editor	Viewer	Viewer
Removed from one base	Editor	No access	No access (base hidden)
Base-only member	—	Commenter	Commenter (only that base appears)
Workspace owner	Owner	Viewer / No access	Creator (owners can't be restricted)
Expired grant	Editor until yesterday	—	No access
Suspended	anything	anything	No access

6. Who can give access, and how

Path	Who can use it	What it does
Sign-up	Anyone	New organization (Owner) + workspace "Home" (Owner).
Create workspace	Organization Owner (= everyone, in their own org)	Creator of the workspace becomes its Owner.
Create base	Workspace Owner / Creator	Creator of the base becomes base Creator.
Members & access → Invite	Organization Owner	Email + "Selected bases only" (tick any bases, any workspaces) or "Workspace · X (all its bases)" + role. One invitation and one email even for several bases. Link valid 7 days; must be accepted with the invited email.
Home → workspace *Share*	Organization Owner	Invites to the **whole workspace** (all bases). This is how "one base gave the whole workspace" happened on live.
Members & access → member → Edit access	Organization Owner	Set/clear any workspace or base role, "No access to this base", "Access until"; tick several rows to change them at once; Reset to workspace role.
Suspend / Remove	Organization Owner	See 4.5. The Owner's own access can't be changed.
Devices	Organization Owner	Approve / deny / revoke / rename / forget devices; per-person log of sessions and decisions.
API tokens	Organization Owner	Create/revoke tokens; a token stops working if its creator is no longer an active Owner.
Field permissions	Base Creator	Per-field edit rights.
Share links	Base Editor / Creator	Public or password links to views, base, forms.

Nobody except the organization Owner can invite or change access — not workspace Owners, not base Creators, not Admins. In Airtable, workspace owners and base creators can invite.

7. Full privilege matrix

✓ = allowed. Workspace Owner and organization Owner/Admin act as base Creator on bases. Org Owner = organization Owner. "Author" = the person who created the item.

7.1 Organization level

Action	Org Owner	Org Admin*	Member
Invite people (workspace or bases)	✓	—	—
Change roles, access dates, "No access", bulk changes	✓	—	—
Suspend, reactivate, remove members	✓	—	—
Approve / revoke devices; see device & session log	✓	—	—
Create / revoke API tokens	✓	—	—
Security settings (require device approval)	✓	—	—
Create workspaces in this organization	✓	—	— (but can in their own org)
Upgrade plan	✓	— (Billing admin: ✓)	—
Receive wrong-password and device-approval alerts	✓	—	—

* Admin cannot currently be assigned.

7.2 Workspace level

Action	Org Owner	WS Owner	WS Creator	WS Editor / Commenter / Viewer	Base-only member
See the workspace on Home	✓	✓	✓	✓	**✓ (only their bases)**
See the workspace's member list	✓	✓	✓	✓	—
See the workspace contacts directory	✓	✓	✓	✓	**✓ (see gap G9)**
Create bases	✓	✓	✓	—	—
Rename / delete the workspace	✓	✓	—	—	—
Invite / manage members	✓	—	—	—	—

7.3 Base — data and structure

Action	Viewer	Commenter	Editor	Creator
Open the base, read records, search inside it	✓	✓	✓	✓
Export CSV / Excel	✓	✓	✓	✓
Record revision history; see trash	✓	✓	✓	✓
Duplicate the whole base (into a workspace where they can create bases)	**✓ (G2)**	**✓ (G2)**	✓	✓
Create, edit, delete, duplicate, reorder records; import CSV	—	—	✓	✓
Link / unlink records	—	—	✓	✓

Upload attachments	—	—	✓	✓
Undo / redo (own changes only); restore records from trash	—	—	✓	✓
Add, change, delete fields and tables; set primary field; restore fields/tables	—	—	—	✓
Field permissions	—	—	—	✓
Rename the base; delete the base	—	—	—	✓
Rebuild the search index	—	—	—	✓

7.4 Views

Action	Viewer	Commenter	Editor	Creator
See collaborative and locked views; own personal views	✓	✓	✓	✓
Create / edit / delete **personal** views (only their own)	—	✓	✓	✓
Create / edit / delete **collaborative** views; reorder views	—	—	✓	✓
Edit a **locked** view; lock / unlock	—	—	view author only	✓
Favorite a view	✓	✓	✓	✓

The last collaborative view of a table can't be deleted.

7.5 Comments

Action	Viewer	Commenter	Editor	Creator
Read comments	✓	✓	✓	✓
Write comments, @mention, react, resolve / reopen any thread	—	✓	✓	✓
Edit or delete a comment	Author only (nobody can edit or delete someone else's comment, not even the Owner)			
Follow a record (notification level)	✓	✓	✓	✓

7.6 Share links and forms

- Create, change, regenerate, revoke share links: **Editor and Creator**. List links: anyone with base access. tested (Viewer: refused, 403).
- Link types: **view** (read that view), **base** (read the whole base), **form** (submit only, including file uploads). Visitors never edit.
- Options: public or **password**; **expiry date**; "allow copy" (display hint only — not enforced by the server).
- Wrong passwords: 5 tries → 15-minute lock for that visitor, and the organization Owner is alerted (email + IP).
- Form submissions are created as "Form" (no account needed), count toward the plan's record limit and are rate-limited.

7.7 Interfaces

- **Build** (create, edit, publish, pages): base **Creator**. **Use** published interfaces: any base role (non-builders only see published ones). There is no "interface-only" access yet — to use an interface a person needs a role on the base.

7.8 Automations

Action	Who
See automations and their run history	Any base role
Create, edit, duplicate, delete, test, get webhook URL	Creator
Press an automation button in a record	Editor and Creator
Incoming webhook trigger	Anyone with the secret webhook URL
Whose permissions and connected accounts (Gmail, Slack, …) the actions use	The person who **last saved** the automation (otherwise its creator). If that person loses access, the actions fail.

7.9 Synced tables and connectors

- Connections (Gmail, Slack, HubSpot, Airtable) belong to **the person** who connected them, not to the organization. Others can't use or see someone else's connection.
- Create a synced table: base **Creator**, using **their own** connection (or, for a table from another base, read access to that base in the same organization).
- Sync now / Stop: **Editor and Creator**. Pause, resume, two-way, "keep as text", stop syncing: **Creator**. Two-way can only be turned on by the person who set up the sync.
- Synced fields are read-only for everyone (except fields made writable by two-way HubSpot sync).

7.10 Attachments, import, export

- Upload: Editor and Creator. Download: anyone with base access. File links in records are signed and expire.
- Import: Editor and Creator. Export (CSV/Excel): **every role, including Viewer** (G4).

7.11 Search, notifications, contacts

- Search only returns bases the person can open.
- Notifications are personal; they are not re-checked when someone loses access to a base (G17).
- The workspace contacts directory only requires organization membership (G9).

7.12 API tokens

- Only the organization Owner creates them. Scopes: **read**, **write**, **delete**; optionally limited to chosen bases; optional expiry.
- A token can reach only the records API and schema reads (`access/api-tokens.ts` `requiredScope`); everything else is refused.
- A token works only while it is unrevoked, unexpired and its creator is still an active Owner of the organization. It acts with the Owner's access.

8. Security controls

Control	How it works today
Device approval	On by default per organization. A member's new browser is "Waiting" until the Owner approves it; until then that organization's data is invisible to them. Revoked devices are blocked even if approval is turned off. The Owner gets a bell notification and has a per-person log (devices, active/ended sessions, approvals and revocations). Owners never need approval.
Wrong passwords (sign-in)	Warning from the 3rd try, 15-minute lock after 5 wrong passwords; the organization Owner is alerted with the email and IP. The Owner's own account is never locked (it is still rate-limited: 10 tries per 15 minutes per IP).
Wrong passwords (share links)	Same policy per visitor IP; Owner alerted.
Sessions	Never expire (since 0.8.1): you stay signed in until you sign out, change your password, or the Owner removes or suspends you or revokes the device. Each person can sign out other sessions.
Two-factor (MFA)	Optional per person (authenticator app). Not enforceable by the organization.
Audit log	Sign-ins, failed sign-ins, invitations, role changes, device decisions, share links, API tokens and sync settings are recorded (not yet viewable in the app except the device log).

9. Account types: what each person actually sees

Person	What they see and can do
Company owner (signed up, invites the team)	Everything in the company organization; Members & access; alerts. Also cannot be restricted, locked out or asked for device approval.
Member with a workspace role	That workspace with all its bases at that role (minus bases set to "No access"). **Plus** their own personal organization with its own "Home" workspace, where they are Owner and can create workspaces and bases.
Member with selected bases	The workspace(s) containing those bases, showing only those bases. Plus their own personal organization, as above. Can copy any base they can read into their own workspace (G2).
Suspended member	Nothing in the company organization; their own organization still works.
Removed member	Nothing in the company organization. Anything they exported or created in their own organization stays with them.
Someone who just signs up (not invited)	A brand-new organization of their own with "Home". Nothing of yours.
Share-link visitor	Only the shared view, base (read-only) or form (submit). No account.
Program with an API token	Records API within the token's scopes and bases, acting as the Owner.
Automation	Acts as the person who last saved it, within that person's access.

10. Gaps and risks

Severity: **Critical** data can leave your control · **High** wrong people can do important things · **Medium** missing control or confusing behaviour · **Low** polish.

#	Severity	Gap — what happens today	Evidence
G1	High closed 0.14.0	**Every account owns a personal organization.** Sign-up always creates an organization (Owner) + "Home" (workspace Owner), including for people you invite. They therefore see two organizations mixed on Home (both workspaces called "Home") and have a private place where they can create workspaces and bases outside your control. tested	`auth/routes.ts` 173–221
G2	Critical closed 0.14.0	**Any role can copy a whole base, with records, into their own workspace.** Duplicating only checks "can read the source" and "can create bases in the target workspace" — not that the target is in the same organization, and not that the person is a Creator. A Viewer duplicated a company base into their own "Home" and became Creator of the copy. After the Owner removed them they lost the copy, but the copy remains inside the company's data, not listed in any company workspace (orphaned). tested	`base/manage-routes.ts` 152–174; `base/duplicate-base.ts`
G3	High closed 0.14.0	**Everyone can create workspaces.** The server only requires being Owner of *an* organization, which everyone is (G1); + *Create workspace* is shown to everybody and silently creates it in the person's own organization. There is no setting "Who can create workspaces". tested	`workspace/routes.ts` 70–118; Home sidebar
G4	High closed 0.14.0	**Export cannot be restricted.** Viewer and Commenter can download every table as CSV/Excel (and see all data through the base's API with a token if they are Owner). Airtable lets owners restrict export to Creators. tested	`permissions/authorize.ts` (viewer has `export.data`); `import-export/routes.ts` 292, 354
G5	High closed 0.14.0	**Open sign-up.** Anyone who reaches the site can create an account and an organization; there is no invite-only mode or allowed-email-domain rule.	`auth/routes.ts` signup (public)
G6	High closed 0.15.0	**Single point of control.** Only the organization Owner can invite, change roles, approve devices or create tokens. Ownership can't be transferred and there can't be a second Owner. If the Owner is away or leaves, nobody can manage access.	`members/routes.ts` `ownerOrg` 68–75; `invitations/routes.ts`
G7	Medium closed 0.15.0	**Admin role half-built.** Admin gets Owner-level data access (Owner of every workspace) but cannot manage people, and no screen or API can assign it. Billing admin and Guest are unused.	`access/workspace-access.ts` 29–31; no assigning route
G8	Medium closed 0.15.0	**No delegated invites.** Workspace Owners and base Creators can't invite collaborators (Airtable allows it). The workspace Owner role can't be given to anyone else.	`invitations/routes.ts` 120–137
G9	Medium closed 0.14.0	**Contacts directory is open to every organization member**, including people invited to one base only.	`contacts/routes.ts` 48–51; `access/helpers.ts` 6–27
G10	Medium	**No interface-only access.** To use an interface a person needs a role on the whole base. The `interface_only` role exists but isn't offered.	`permissions/roles.ts`; `interfaces/routes.ts`

G11	Medium closed 0.15.0	**Two invite screens behave differently.** Home → workspace *Share* always gives the whole workspace; Members & access offers selected bases. This caused "I gave one base and they got the whole workspace" on live.	`routes/home.tsx` share dialog
G12	Medium closed 0.16.0	**Sessions never expire.** An unattended or stolen browser stays signed in until signed out, password changed, device revoked or member removed. No organization policy for session length.	migration `0076_sessions_no_expiry.sql`
G13	Medium closed 0.16.0	**Owner account is the softest high-value target.** It is exempt from lockout and device approval and MFA is optional; nobody can require MFA.	`auth/lockout.ts` 74–81; `access/devices.ts`
G14	Medium closed 0.16.0	**Public share links need no approval.** Any Editor can publish a view or the whole base on a public link; no organization switch to disable public links or require passwords. "Allow copy" isn't enforced by the server.	`share/routes.ts` 198–290
G15	Low closed 0.16.0	**Field permission "Nobody" also locks out the Owner** and Creators until changed.	`schema/field-permissions.ts` 35
G16	Low closed 0.16.0	**Automations change identity when someone else saves them**: they then run with that person's access and connected accounts.	`automations/engine.ts` 742
G17	Low closed 0.16.0	**Old notifications stay visible** after someone loses access to a base (title and preview text).	`notifications/routes.ts`
G18	Low closed 0.16.0	**No "move base to another workspace".** Only duplicate (which leaves the original and has gap G2).	`base/manage-routes.ts`
G19	Low closed 0.16.0	**Workspace member lists show every member's email** to all workspace members (also Viewers).	`workspace/routes.ts` 190–250
G20	Low closed 0.16.0	**No audit screen.** Role changes, invitations and share links are logged but only the device log can be viewed.	`audit.audit_events`

11. Recommended model and decisions needed

11.1 Target model (Airtable-aligned, organization-centric)

```
Organization (your company — the only place company data lives)
├── Owners        one or more; transferable; everything incl. billing
├── Admins        manage people, devices, workspaces, policies (no billing)
├── Billing admin plan and invoices only
├── Members       get access only through workspace / base roles
└── Guests        base-only people; can never create workspaces or bases

Organization policies (new settings, defaults in brackets)
  • Who can create workspaces ..... [Owners and Admins]
  • Who can invite people ..... [Owners and Admins]  (+ workspace Owners, + base Creators)
  • Who can export data (CSV/Excel/API) ... [Creators and up]
  • Public share links ..... [Allowed, password required]
  • Copy bases outside the organization ... [Never]
  • Require two-factor ..... [Off]
  • Session length ..... [30 days]
  • Sign-up ..... [Invite only]  (or allowed email domains)

Workspace roles:  Owner (assignable, can manage that workspace's people) · Creator · Editor ·
Commenter · Viewer
Base roles:       Creator · Editor · Commenter · Viewer · Interface only · No access
```

11.2 Proposed changes by phase

Phase	Change	Fixes
1 — urgent	Duplicating a base requires **Creator** on the source and a target workspace **in the same organization**; clean up existing cross-organization copies.	G2, G18
1	Organization setting "Who can create workspaces" (default Owners and Admins); hide + *Create workspace* for others; when someone belongs to several organizations, ask which organization the workspace is for.	G3
1	Organization setting "Who can export data"; enforce it on CSV/Excel export and the API.	G4
1	Contacts directory requires a workspace role.	G9
2 — structure	Invite-only sign-up (or allowed email domains); invited people **don't get a personal organization** (existing personal organizations of invited members: keep, hide or remove — your decision).	G1, G5
2	Assignable **Admin** role with people management; multiple Owners and **transfer ownership**.	G6, G7
2	Delegated invites (setting): workspace Owners invite to their workspace, base Creators to their base; workspace Owner assignable.	G8
2	One invite dialog everywhere (whole workspace or selected bases).	G11
3 — hardening	Session length policy; "require two-factor" policy (incl. Owners).	G12, G13
3	Share-link policy (disable public / require password); enforce "allow copy".	G14
3	Interface-only access; audit log screen; hide notifications for bases you can't open; "move base" between workspaces; automation run-as shown and changeable.	G10, G15–G20

11.3 Decisions we need from you

1. **Sign-up:** invite only, allowed email domains (e.g. @bluecascade.org), or open?
2. **Personal organizations of invited people** (e.g. Mahad's own "Home"): keep, hide, or remove (after moving anything important)?
3. **Who may create workspaces:** Owners only, Owners and Admins, or a list of people?
4. **Who may invite:** Owners/Admins only, or also workspace Owners and base Creators?
5. **Export:** who may download data — Creators only, Editors and up, or everyone?
6. **Public share links:** allowed, allowed with password only, or off?
7. **Admins:** who should be Admin, and should Admins also see billing?
8. **Security:** require two-factor? Session length (never / 30 days / 7 days)?

Appendix A — API route → permission map

Grouped by area. "creator" = needs `base.manage_schema` (or `base.manage_members` for deleting a base); "editor" = `record.create/update/delete` or `view.update`; "commenter" = `record.comment`; "any role" = any effective base role. All routes need a signed-in session or an API token unless marked public.

Route	Needs	Notes
Accounts & organization		
`POST /v1/auth/signup`, `/login`, `/mfa/verify`, `/logout`, Google	public	Login lockout; sign-up creates an organization
`/v1/auth/me`, `/password`, `/sessions`, `/mfa/*`	signed in	Own account only
`GET /v1/orgs`, `GET /v1/devices/current`	signed in	Own memberships / this device
`/v1/orgs/:org/access`, `/members/*`, `/grants`, `/devices/*`, `/device-log`, `/api-tokens/*`, `/settings`	org Owner	
`POST /v1/invitations`, `GET`, `DELETE`	org Owner	One or several bases, or a workspace
`GET /v1/public/invitations/:token`; `POST /v1/invitations/accept`	public / signed in	Must match the invited email; becomes `member`
`/v1/billing/plan` · `/upgrade`, `/checkout`	member · Owner or Billing admin	
Workspaces & bases		
`GET /v1/workspaces`	signed in	Workspaces where they have a role or a base
`POST /v1/workspaces`	Owner of any organization	Created in their first owned organization (G3)
`PATCH` / `DELETE /v1/workspaces/:w`	workspace Owner	
`GET /v1/workspaces/:w/members`	workspace role	Base-only members excluded
`GET /v1/workspaces/:w/bases`	org member	Filtered to bases they can open
`POST /v1/workspaces/:w/bases`	workspace Owner/Creator	
`/v1/workspaces/:w/contacts*`	org member	G9
`GET /v1/bases/:b`, `/changes`, `/hidden-tables`	any role	Personal views only for their owner
`PATCH /v1/bases/:b` · `DELETE`	creator	Rename · delete (30-day trash)
`POST /v1/bases/:b/duplicate`	any role + target workspace Owner/Creator	G2 — no same-organization check
`GET /v1/bases/:b/collaborators`	any role	
Schema		
`GET …/tables`, `…/fields`	any role	
Create / rename / delete / duplicate / reorder tables and fields; primary field; `PUT …/fields/:f/permissions`	creator	

Records, links, query, history		
`POST …/records/query`, `GET …/records/:r`, `…/group`	any role	
Create / update / delete / batch / duplicate / move records	editor	Field permissions; synced fields read-only
Link / unlink records · create link field	editor · creator	
`GET …/records/:r/history`	any role	Kept 14 days on the current plan
`…/undo`, `…/redo`	editor	Own changes only
`GET …/trash` · `POST …/trash/restore`	any role · editor (records) / creator (tables, fields)	
Views & comments		
`POST …/views`	commenter (personal) · editor (shared/locked)	
`PATCH` / `DELETE …/views/:v`, reorder	owner of personal view · editor (shared) · author or creator (locked)	Last shared view can't be deleted
`GET …/comments` · `POST`, resolve, reactions	any role · commenter	Edit/delete: author only
Sharing, forms, interfaces		
`GET …/shares` · create / update / regenerate / revoke	any role · editor	
`/v1/public/shares/:token/*`	public (link + password)	Read view/base; submit form
Interfaces: build · use published	creator · any role	
Automations, syncs, connectors		
Automations: list, runs · manage, test, webhook URL · button trigger	any role · creator · editor	Runs as last saver
`POST /v1/hooks/:token`	public (secret URL)	
Syncs: view, issues · run, stop · create, pause, resolve, remove	any role · editor · creator	Own connection needed
`/v1/connections*`	signed in	Own connections only
Files, import/export, search, notifications		
Attachment presign/upload · download	editor · any role	Public signed file links expire
Import · export	editor · any role (G4)	
`GET /v1/search` · reindex	signed in · creator	Only bases they can open
`/v1/notifications*`	signed in	Own notifications
API token calls	scope read/write/delete	Records API and schema reads only

Appendix B — Where it lives in the code and database

Topic	Location
Role list and actions per role	`packages/permissions/src/roles.ts`, `actions.ts`, `authorize.ts`
Effective role rules (workspace vs base, "none")	`packages/permissions/src/snapshot.ts` (`combineBaseRole`); `apps/server/src/modules/access/compile.ts`
Organization roles, workspace access	`apps/server/src/modules/access/workspace-access.ts`, `helpers.ts`
Sign-up (personal organization + Home)	`apps/server/src/modules/auth/routes.ts`
Invitations	`apps/server/src/modules/invitations/routes.ts`
Members & access, devices, API tokens (server)	`apps/server/src/modules/members/routes.ts`, `access/devices.ts`, `access/api-tokens.ts`
Members & access (screen)	`apps/web/src/features/admin/AdminPage.tsx`
Workspaces and bases	`apps/server/src/modules/workspace/routes.ts`, `base/routes.ts`, `base/manage-routes.ts`, `base/duplicate-base.ts`
Field permissions	`apps/server/src/modules/schema/field-permissions.ts`; enforced in `records/write.ts`
Lockout and alerts	`apps/server/src/modules/auth/lockout.ts`
Auth check on every request	`apps/server/src/http/auth-hook.ts`

Database table	Holds
`core.organizations`	Organizations (kind `personal` for sign-up ones), settings (e.g. device approval)
`core.organization_members`	Organization role (owner/admin/billing_admin/member/guest) and status (active/suspended/deactivated)
`core.workspaces`, `core.base_directory`	Workspaces and bases (with their organization)
`core.access_grants`	Workspace and base roles per person, incl. `none`, expiry, who granted
`core.invitations`	Pending/accepted invitations (workspace, base, extra bases, role, expiry)
`core.org_devices`, `core.sessions`	Devices (pending/approved/revoked) and sign-in sessions
`core.api_tokens`	API tokens (scopes, bases, expiry)
`data.fields.edit_permission`	Field permissions
`audit.audit_events`	Audit log

End of document.